

Security Assessment Report

Automated Authentication & Authorization Security Assessment

Target	SECUREHUB
URL	https://securehub-di8a.onrender.com
Assessment Type	Automated Access Control Security Testing
Generated	08 October 2026, 14:31:49

RBAC • JWT • Horizontal Authorization / IDOR • JWT Validation

1. EXECUTIVE SECURITY SUMMARY

TOTAL	PASSED	FAILED	SKIPPED	ERRORS
32	30	2	0	0

X OVERALL SECURITY RESULT: FAIL

2. SECURITY TEST COVERAGE

Security Category	Total	Passed	Failed
Authentication	8	7	1
Authorization	14	14	0
Horizontal Authorization / IDOR	2	2	0
JWT Validation	8	7	1

3. ASSESSMENT SCOPE

The assessment evaluated authentication enforcement, role-based authorization, horizontal authorization boundaries, vertical privilege separation, JWT validation, and protected API resource access using the configured security policy and resource ownership rules.

4. DETAILED SECURITY TEST RESULTS

ID	ROLE	CATEGORY	METHOD	ENDPOINT	RULE	EXP.	ACT.	RESULT
AC-0001	anonymous	Authentication	POST	/api/auth/logout	Authentication control failure: anonymous received HTTP 200 for POST /api/auth/logout; expected HTTP status 401, 403, 302.	401, 403, 302	200	FAIL
AC-0002	invalid-token	JWT Validation	POST	/api/auth/logout	Authentication control failure: invalid-token received HTTP 200 for POST /api/auth/logout; expected HTTP status 401, 403, 302.	401, 403, 302	200	FAIL
AC-0003	admin	Authorization	POST	/api/auth/logout	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0004	user	Authorization	POST	/api/auth/logout	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0005	anonymous	Authentication	GET	/api/users	Control evaluated	401, 403, 302	302	✓ PASS
AC-0006	invalid-token	JWT Validation	GET	/api/users	Control evaluated	401, 403, 302	302	✓ PASS

ID	ROLE	CATEGORY	METHOD	ENDPOINT	RULE	EXP.	ACT.	RESULT
AC-0007	admin	Authorization	GET	/api/users	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0008	user	Authorization	GET	/api/users	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0009	anonymous	Authentication	GET	/api/orders	Control evaluated	401, 403, 302	302	✓ PASS
AC-0010	invalid-token	JWT Validation	GET	/api/orders	Control evaluated	401, 403, 302	302	✓ PASS
AC-0011	admin	Authorization	GET	/api/orders	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0012	user	Authorization	GET	/api/orders	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0013	anonymous	Authentication	GET	/api/documents	Control evaluated	401, 403, 302	302	✓ PASS
AC-0014	invalid-token	JWT Validation	GET	/api/documents	Control evaluated	401, 403, 302	302	✓ PASS
AC-0015	admin	Authorization	GET	/api/documents	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0016	user	Authorization	GET	/api/documents	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0017	anonymous	Authentication	GET	/api/documents/{doc_id}	Control evaluated	401, 403, 302	302	✓ PASS

ID	ROLE	CATEGORY	METHOD	ENDPOINT	RULE	EXP.	ACT.	RESULT
AC-0018	invalid-token	JWT Validation	GET	/api/documents/{doc_id}	Control evaluated	401, 403, 302	302	✓ PASS
AC-0019	admin	Horizontal Authorization / IDOR	GET	/api/documents/{doc_id}	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0020	admin	Horizontal Authorization / IDOR	GET	/api/documents/{doc_id}	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0021	anonymous	Authentication	GET	/api/tickets	Control evaluated	401, 403, 302	302	✓ PASS
AC-0022	invalid-token	JWT Validation	GET	/api/tickets	Control evaluated	401, 403, 302	302	✓ PASS
AC-0023	admin	Authorization	GET	/api/tickets	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0024	user	Authorization	GET	/api/tickets	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0025	anonymous	Authentication	GET	/api/reports	Control evaluated	401, 403, 302	302	✓ PASS
AC-0026	invalid-token	JWT Validation	GET	/api/reports	Control evaluated	401, 403, 302	302	✓ PASS
AC-0027	admin	Authorization	GET	/api/reports	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0028	user	Authorization	GET	/api/reports	Control evaluated	200, 201, 202, 204	200	✓ PASS

ID	ROLE	CATEGORY	METHOD	ENDPOINT	RULE	EXP.	ACT.	RESULT
AC-0029	anonymous	Authentication	GET	/api/notifications	Control evaluated	401, 403, 302	302	✓ PASS
AC-0030	invalid-token	JWT Validation	GET	/api/notifications	Control evaluated	401, 403, 302	302	✓ PASS
AC-0031	admin	Authorization	GET	/api/notifications	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0032	user	Authorization	GET	/api/notifications	Control evaluated	200, 201, 202, 204	200	✓ PASS

5. SECURITY FINDINGS

AC-0001	FAIL
Finding	Authentication control failure: anonymous received HTTP 200 for POST /api/auth/logout; expected HTTP status 401, 403, 302.
Evidence	HTTP 200 from POST /api/auth/logout
Request	https://securehub-di8a.onrender.com/api/auth/logout
Expected	401, 403, 302
Actual	200
Response Body	{'message': 'Logout successful', 'success': True}

AC-0002	FAIL
Finding	Authentication control failure: invalid-token received HTTP 200 for POST /api/auth/logout; expected HTTP status 401, 403, 302.
Evidence	HTTP 200 from POST /api/auth/logout

AC-0002	FAIL
Request	https://securehub-di8a.onrender.com/api/auth/logout
Expected	401, 403, 302
Actual	200
Response Body	{'message': 'Logout successful', 'success': True}

6. ASSESSMENT CONCLUSION

A total of **32** automated security tests were executed. **30** passed, **2** failed, **0** were skipped, and **0** produced errors.

X OVERALL SECURITY RESULT: FAIL